Table of Contents

Cisco Secure Workload — NIST 800-53 Rev 5 Compliance Framework

Reference Design | Federal & Enterprise Accounts

Version: 1.0 | **Standard:** NIST SP 800-53 Rev 5 (CSW-Relevant Control Families)

Reader's Guide

Who this is for. Federal agencies (civilian and DoD), FedRAMP applicants, and enterprises that have adopted 800-53 as a security overlay, plus the assessors supporting them.

Questions this reference design helps you answer:

- *For my system's impact level (LOW / MODERATE / HIGH), which AC, AU, CM, and SC controls become continuous monitoring rather than periodic-assessment items?* (CA-7)
- *Can my POA&M be partially burned down through automated CSW evidence rather than manual remediation tracking?* (CA-5, RA-5)
- *For SC-7 boundary protection, what is my evidence at the workload tier — distinct from perimeter firewalls and CSPM?*
- *For SI-4 system monitoring, can I show end-to-end visibility from process initiation through network conversation to data store?*
- *If my assessor wants machine-readable artifacts (OSCAL-adjacent), what does CSW produce vs. what still requires narrative documentation?*

What you'll need. Your system's FIPS 199 categorization, a current or draft System Security Plan (SSP), your control overlay if any (e.g., HIGH baseline, FedRAMP Mod), and your assessor's evidence format expectations.

Where to start. Section 2 walks the seven control families CSW addresses most directly; sections 3–4 build the scope tree and the AC-4 / SC-7 policy set that the control mapping depends on; section 5 maps coverage by impact level; go to section 6 if you're building the evidence package now.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	**Live** network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement **operates**

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: Compliance evidence playbook (full step-by-step) · About CSW (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
		owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- AC-4 information-flow enforcement with exportable policy artefacts
- CA-7 continuous monitoring via inventory, flows, and violations
- CM-2/3/8 baseline and change tracking through ADM drift

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

---

1. Overview

NIST SP 800-53 Rev 5 provides a comprehensive catalog of security and privacy controls for federal information systems. CSW can support technical evidence for selected controls across seven key families: **AC** (Access Control), **AU** (Audit & Accountability), **CM** (Configuration Management), **IR** (Incident Response), **RA** (Risk Assessment), **SC** (System & Communications Protection), and **SI** (System & Information Integrity).

---

2. Control Family Mapping

AC — Access Control

Control	Name	CSW Implementation
AC-3	Access Enforcement	Micro-segmentation enforces allowlist policies at workload level
AC-4	Information Flow Enforcement	ADM maps observed flows within CSW coverage; policy blocks unauthorized paths where enforcement is deployed
AC-6	Least Privilege	Workload-scoped policies grant minimum required network access
AC-17	Remote Access	Jump-host enforcement; remote admin paths explicitly defined and logged
AC-20	Use of External Systems	External partner scope with restricted, audited

Control	Name	CSW Implementation
		access paths

CSW Implementation:

```
CSW UI → Defend → Segmentation
  → Policy type: Allowlist (default deny)
  → Scope: target workload group
  → Document each allowed flow with business justification
  → Export policy for AC-3/AC-4 control evidence
```

AU — Audit & Accountability

Control	Name	CSW Implementation
AU-2	Event Logging	Full network flow + process telemetry on all monitored workloads
AU-3	Content of Audit Records	5-tuple flows + process name + user context + timestamp
AU-6	Audit Record Review	Alerts export to SIEM for automated review; anomaly detection
AU-9	Protection of Audit Information	CSW telemetry stored in tamper-resistant cluster
AU-12	Audit Record Generation	Continuous logging; configurable retention (recommend 3 years for federal)

Log Content per AU-3:

- Source/destination IP and port
- Protocol and direction
- Process name and hash
- Parent process context
- User context (where OS supports)
- Policy action (allow/deny/alert)
- Timestamp (UTC, microsecond precision)

CM — Configuration Management

Control	Name	CSW Implementation
CM-2	Baseline Configuration	ADM establishes approved communication baseline

Control	Name	CSW Implementation
CM-6	Configuration Settings	Process monitoring detects configuration drift (new processes, new ports)
CM-7	Least Functionality	Block non-approved services via port-level policy enforcement
CM-8	System Component Inventory	CSW inventory provides a workload asset catalog for covered components; reconcile with the SSP / CMDB for full CM-8 scope

Baseline Drift Detection:

```
CSW UI → Investigate → ADM
  → Re-run ADM quarterly
  → Compare to previous baseline
  → New flows = configuration change review required
  → Policy workspace updated to reflect approved changes
```

IR — Incident Response

Control	Name	CSW Implementation
IR-4	Incident Handling	Forensic telemetry enables full incident reconstruction
IR-5	Incident Monitoring	Real-time anomaly alerts; policy violation events
IR-6	Incident Reporting	Alert export to SIEM/SOAR for automated incident ticket creation
IR-10	Integrated Information Security Analysis	CSW correlates network + process + vulnerability context per incident

Forensic Investigation Workflow:

```
1. Alert triggered → CSW alert with workload ID, time, flow context
2. Flow Search → reconstruct all connections from/to affected workload
3. Process Search → identify anomalous processes + parent chain
4. Vulnerability Report → identify exploited CVE if applicable
5. Export → full forensic package for IR team
```

RA — Risk Assessment

Control	Name	CSW Implementation
RA-3	Risk Assessment	Vulnerability data + ADM attack surface = continuous risk posture
RA-5	Vulnerability Monitoring	Continuous vulnerability exposure visibility with CVSS scoring
RA-7	Risk Response	Compensating controls via policy when patching delayed
RA-9	Criticality Analysis	Scope-based tagging identifies high-criticality workloads

SC — System & Communications Protection

Control	Name	CSW Implementation
SC-7	Boundary Protection	Micro-segmentation enforces east-west boundaries
SC-8	Transmission Confidentiality	Detect and block unencrypted sensitive data flows
SC-28	Protection of Information at Rest	Identify workloads with unencrypted storage access paths
SC-39	Process Isolation	Workload-level policy ensures process-to-process isolation

SI — System & Information Integrity

Control	Name	CSW Implementation
SI-2	Flaw Remediation	Continuous vulnerability exposure view; prioritized remediation guidance
SI-3	Malicious Code Protection	Process hash monitoring provides detection signals that complement AV / EDR controls
SI-4	System Monitoring	Full telemetry with anomaly detection and

Control	Name	CSW Implementation
		alerting
SI-7	Software & Firmware Integrity	Process hash baseline from ADM; deviation triggers alert

3. Scope Architecture and Labeling

The control families in section 2 are only auditable against a named boundary. In an 800-53 engagement that boundary already exists on paper — it is the authorization boundary in the SSP — so the job here is to make the CSW scope tree a mirror of the SSP rather than a second, competing inventory. When the two diverge, the assessor treats the CSW export as unreliable, which is a harder finding to close than a missing control.

3.1 Suggested Scope Architecture

```
Root Scope
└── Authorization-Boundary                (mirrors the SSP system
boundary)
    ├── High-Impact-Systems               (FIPS 199 high)
    │   ├── Mission-Applications
    │   └── System-of-Record-Data-Stores
    ├── Moderate-Impact-Systems
    ├── Shared-Services                   (common / inherited
controls)
    │   ├── Identity-Services
    │   ├── Logging-and-Monitoring
    │   └── Patch-and-Config-Mgmt
    ├── Privileged-Access-Paths           (AC-17 remote
administration)
    └── External-Systems                  (AC-20 — outside the
boundary)
```

`External-Systems` is deliberately inside the tree even though it sits outside the authorization boundary. AC-20 requires you to evidence the terms of external system use, and you cannot show a flow to a system the scope tree refuses to name.

3.2 Inventory Filters

```
Filter: High-Impact-Systems
  - Tag: fips199_impact = high
  - Tag: system_id matches the SSP system identifier
  - Hostname / application pattern matches the SSP component inventory

Filter: System-of-Record-Data-Stores
  - Tag: data_type = pii | phi | federal-record
  - Listening port: 1433, 1521, 3306, 5432, 27017

Filter: Privileged-Access-Paths
```

```
  - Listening port: 22, 3389, 5985, 5986
  - Tag: application = bastion | jump-host

Filter: External-Systems
  - Destination outside the documented boundary allow-lists
  - Tag: managed_by = external | contractor
```

3.3 Labeling Strategy

Label key	Example values	Why it matters for 800-53
`system_id`		Reconciles the CSW inventory to the SSP component table — the CM-8 pivot
`fips199_impact`	high, moderate, low	Sets enforcement stringency per section 5 and drives control selection
`control_inheritance`	common, hybrid, system-specific	Shows which controls the system inherits from Shared-Services versus implements itself
`data_type`	pii, phi, federal-record, internal, public	Supports SC-28 / RA-2 categorisation and plaintext-flow findings
`authorization_boundary`	in, out	Makes the AC-20 external-system question a filter rather than an interview
`application`		Connects workloads to SSP-named components
`owner`		Accountability (system owner / ISSO)
`compliance`	nist-800-53	Filters CSW evidence to the accreditation boundary

`system_id` and `control_inheritance` are the two labels worth enforcing at onboarding. Together they let you answer the question that otherwise costs an assessor interview: for this workload, which controls are inherited, which are hybrid, and where is the evidence for each.

---

4. Policy Design — AC-4 and SC-7 Enforcement

AC-4 and SC-7 are the two controls where CSW produces primary rather than supporting evidence, so the policy set should be written to be read by an assessor, not only by an operator. Each rule below is a sentence in the SSP's information-flow narrative.

4.1 Control-Aligned Policy Framework

Absolute policies:

```
DENY  Any                          → High-Impact-Systems
(default deny inbound — SC-7, AC-4)
DENY  High-Impact-Systems          → Internet                          (no
direct egress from high-impact — SC-7)
DENY  External-Systems             → Authorization-Boundary            (no
undocumented external path — AC-20)
DENY  Moderate-Impact-Systems      → High-Impact-Systems               (no
impact-level downgrade path — AC-4)
```

The fourth rule is the one assessors probe hardest. AC-4 is about flow *between* categorisations, so a moderate-impact workload with an unrestricted path into a high-impact store is a finding even when both systems are individually compliant.

Allowlist policies (least privilege):

```
ALLOW Mission-Applications         → System-of-Record-Data-Stores
tcp/<db-port-tls>
ALLOW Mission-Applications         → Identity-Services
tcp/636, tcp/88
ALLOW Privileged-Access-Paths      → High-Impact-Systems
tcp/22, tcp/3389
ALLOW Authorization-Boundary       → Logging-and-Monitoring
tcp/443, udp/514
ALLOW Patch-and-Config-Mgmt        → Authorization-Boundary
tcp/443
```

Catch-all:

```
LOG   Any                          → High-Impact-Systems
(unmatched inbound — SI-4)
LOG   High-Impact-Systems          → Any
(unmatched outbound — SI-4)
LOG   Authorization-Boundary       → Any
(plaintext: tcp/80, tcp/21, tcp/23, tcp/389, udp/161)
```

4.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate the candidate policy
2	Enforcement	1 week	Enforce obvious

Phase	Mode	Duration	Purpose
	(high-confidence rules only)		deny rules
3	Full Enforcement	Ongoing	Workload allowlist enforced; monthly exception review

Workspace snapshots are AC-4 and SC-7 implementation evidence; the simulation report is the CM-3 change-control artifact that shows the policy was assessed before it was enforced. Exceptions belong in the workspace exception register, which doubles as the POA&M input.

---

5. NIST Impact Level Guidance

Impact Level	CSW Configuration
Low	ADM + monitoring only; simulation policies
Moderate	ADM + enforcement on sensitive scopes; full alerting
High	ADM + full enforcement; process-level monitoring; 3-year telemetry retention

6. Evidence Package

Evidence Item	CSW Source	Control Family	Frequency
Policy enforcement log	Defend → Policy Workspaces	AC	Per audit
Network flow audit log	Investigate → Flow Search	AU	Continuous
Vulnerability report	Investigate → Vulnerability	RA, SI	Weekly
ADM baseline map	Investigate → ADM	CM	Quarterly
Alert/incident log	Alerts → Dashboard	IR	Monthly
Workload inventory	Manage → Inventory	CM	Monthly
Process anomaly report	Investigate → Process Search	SI	On-demand

Related Frameworks

- ISO/IEC 27001:2022 — the international counterpart for organisations cross-mapping 800-53 to ISO Annex A.
- NIST SP 800-207 — the ZTA architectural overlay on top of the 800-53 control catalogue.
- NIST SP 800-207A — the logical-component view that operationalises AC, SI, SC families.
- FIPS 140 — SC-13 cryptographic-protection requirement for the 800-53 baselines.
- HIPAA — for healthcare entities that satisfy §164.306 via 800-53 mapping.
- UK NCSC CAF v3.2 — AC-4 and SC-7 are the reuse path for CAF B5.

Replace [Customer Name] and bracketed fields before customer delivery.